⚡ Lab 5 – EuroGrid Finance
NIS2 & DORA Regülasyon Uyum Denetimi Deneyimi

Senaryo

Bir bilgi sistemleri denetçisi olarak Avrupa genelinde faaliyet gösteren finansal hizmetler kuruluşu **EuroGrid Finance**'ın siber dayanıklılık ve regülasyon uyumluluk denetimini gerçekleştirmek üzere görevlendirildiniz.
Şirket;

- 12 Avrupa ülkesinde faaliyet göstermektedir
- 6.200 çalışanı bulunmaktadır
- 2.8 milyon müşteriye hizmet vermektedir
- Bulut tabanlı finansal uygulamalar kullanmaktadır
- SWIFT altyapısına bağlıdır
- Kritik ödeme sistemleri işletmektedir
- Avrupa Birliği içerisinde DORA ve NIS2 kapsamındadır

Şirket yönetimi aşağıdaki güvenceyi vermektedir:

- DORA gereksinimlerinin tamamı karşılanmaktadır.
- NIS2 uyumluluğu sağlanmıştır.
- Kritik tedarikçiler etkin şekilde yönetilmektedir.
- Operasyonel dayanıklılık yeterlidir.
- Siber olaylar zamanında raporlanmaktadır.
- İş sürekliliği ve felaket kurtarma süreçleri test edilmektedir.
- Üçüncü taraf riskleri kontrol altındadır.
- Yönetim kurulu siber riskleri düzenli takip etmektedir.
- Kritik varlıklar tanımlanmıştır.
- Tüm ICT hizmetleri envanter altındadır.

Yönetim ekibine göre kurum Avrupa regülasyonlarına tam uyumludur.
Ancak sizden yalnızca beyanlara güvenmeden teknik ve süreçsel kanıtlar toplamanız beklenmektedir.

Şirket Profili

Kritik Sistemler

- Core Banking Platform
- Mobile Banking
- Customer Portal
- SWIFT Infrastructure
- Microsoft 365
- AWS Environment
- Azure Environment
- Payment Gateway

Denetim Kapsamı

Denetim aşağıdaki alanları kapsamaktadır:

DORA

- ICT Risk Management
- ICT Incident Management
- Digital Operational Resilience Testing
- Third Party Risk Management
- Information Sharing

NIS2

- Governance
- Risk Management
- Incident Reporting
- Supply Chain Security
- Business Continuity
- Vulnerability Management
- Cyber Hygiene

İncelenecek Dokümanlar

1. ICT Asset Inventory

Dosya:
ICT_Assets.xlsx
Toplam kayıtlı varlık:
284

BT Operasyon Ekibi Bilgisi:

- 970 Sunucu
- 320 Network Cihazı
- 580 SaaS Uygulaması
- 120 AWS Account
- 35 Azure Subscription

Not:
Envanterde AWS ve Azure kaynakları görünmemektedir.

2. Critical Function Register

Dosya:
Critical_Functions.xlsx
Listelenen Fonksiyonlar:

- E-mail
- HR Portal
- Intranet

Ancak:

- SWIFT
- Mobile Banking

- Payment Processing
- Core Banking

kayıtlı değildir.

3. ICT Risk Register

Dosya:
ICT_Risk_Register.xlsx
Toplam Risk:
14

Örnek:

Risk	Son Güncelleme
Malware	2022
Phishing	2022
Ransomware	2023

Bulunmayan Riskler:

- Cloud Concentration Risk
- Supply Chain Attack
- AI Risk
- Third Party Outage
- Geopolitical Threat

4. Board Reporting

Dosya:
Board_Cyber_Reports.pdf
Son Rapor:
Mayıs 2024

İçerik:

- Açık bulgular bulunmuyor.
- Siber riskler kabul edilebilir seviyededir.

Ancak SOC Dashboard verilerine göre:

- 127 kritik açıklık
- 612 yüksek riskli açıklık

bulunmaktadır.

5. Vulnerability Management

Dosya:
Vulnerability_Scan_Report.pdf

Son Tarama:
15 ay önce

Bulgu Sayısı:

Critical:
127
High:
612
Medium:
1490

Aksiyon Durumu:
Open

6. Patch Management

Dosya:
Patch_Compliance.xlsx

Windows Sunucu Sayısı:
530

Yama Seviyesi:

Durum	Sunucu
Güncel	194
Eksik	336

Kritik Yama Gecikmesi:
En fazla:
247 gün

7. Security Incident Register

Dosya:
Security_Incidents.xlsx

Kayıtlı Olay:
4

SOC Dashboard:
Malware:
43

Phishing:
71

Brute Force:
112

DDoS:
9

Kayıt altına alınmamış olaylar bulunmaktadır.

8. Incident Reporting Procedure

Dosya:
Incident_Reporting.docx

DORA gereksinimi:
24 saat içerisinde ilk bildirim
72 saat içerisinde detaylı rapor

Şirket prosedürü:
"Olaylar uygun zamanda raporlanır."

Süre tanımı bulunmamaktadır.

9. Third Party Inventory

Dosya:
Third_Party_Register.xlsx

Toplam Tedarikçi:
194

Risk Değerlendirmesi Yapılan:
34

Güvenlik Maddesi İçeren Sözleşme:
52

DORA Exit Plan Bulunan:
4

10. Critical ICT Provider Review

Dosya:
Critical_ICT_Providers.xlsx

Kritik Tedarikçiler:
AWS
Microsoft
Cloudflare
CrowdStrike
Okta

Risk Değerlendirme Tarihi:
2022

11. Business Continuity Plan

Dosya:
BCP.pdf

Son Güncelleme:
2022

Son Test:
Yok

RTO:
Belirlenmiş

RPO:
Belirtilmemiş

12. Disaster Recovery Exercise

Dosya:
DR_Test_Results.pdf

Son Test:
Bulunamadı

Operasyon Müdürü:
"Her yıl test ediyoruz."

Kanıt bulunamamıştır.

13. Tabletop Exercise

Dosya:
Tabletop_Exercises.xlsx

Son Tatbikat:
2023

Katılımcılar:
BT Ekibi

Yönetim Kurulu:
Katılmamış

14. Cyber Awareness Program

Dosya:
Awareness_Report.xlsx

Çalışan Sayısı:
6200

Eğitim Tamamlayan:
3910

Tamamlamayan:
2290

Phishing Testi
Başarısız Olanlar:
31%

Yeniden Eğitim:
Bulunmuyor

15. Threat Intelligence Program

Dosya:
Threat_Intelligence_Framework.docx

Son Güncelleme:
2021

IOC Kaynakları:
Belirtilmemiş

Tehdit Beslemeleri:
Tanımlanmamış

16. Logging & Monitoring

Dosya:
SOC_Monitoring_Review.pdf

Log Gönderen Sistem:
43

Toplam Kritik Sistem:
178

SIEM Coverage:
24%

17. Access Review

Dosya:
Privileged_Access_Review.xlsx

Domain Admin:
24

Global Admin:
17

Privileged Access Review:
Son Tarih
Mart 2024

Denetim Tarihi:
Haziran 2026

18. Cloud Security Review

Dosya:
Cloud_Assessment.xlsx

AWS Account:
120

İncelenen:
9

Azure Subscription:
35

İncelenen:
2

Yönetim Görüşmeleri

CEO

"DORA uyumluluğunu tamamladığımızı düşünüyorum."
Kanıt sorulduğunda detay paylaşamamıştır.

CIO

"Kritik sistemlerin tamamı envanter altında."
Ancak envanterde Core Banking görünmemektedir.

CISO

"Olaylarımız raporlanıyor."
SOC kayıtlarıyla çelişmektedir.

Vendor Manager

"Tedarikçi değerlendirmeleri düzenli yapılmaktadır."
194 tedarikçiden yalnızca 34 tanesi değerlendirilmiştir.

Öğrenciden Beklenenler

Aşağıdaki regülasyon başlıkları açısından değerlendirme yapılmalıdır:

DORA

Chapter II

ICT Risk Management

Chapter III

ICT Incident Management

Chapter IV

Digital Operational Resilience Testing

Chapter V

ICT Third Party Risk Management

Chapter VI

Information Sharing

NIS2

Governance

Risk Management

Incident Handling

Supply Chain Security

Vulnerability Management

Cyber Hygiene

Business Continuity

Crisis Management

Teslimat

Öğrenci aşağıdaki çıktıları hazırlamalıdır:

Yönetici Özeti

DORA Gap Assessment

NIS2 Gap Assessment

Risk Değerlendirmesi

Tespit Edilen Bulgular

Root Cause Analysis

Regülasyon Uyum Haritası

Yönetim Kurulu Sunumu

Major / Minor Uyumsuzluk Analizi

Regülatör Denetimi Öncesi Hazırlık Planı